16/10/26

Plan de respuesta ante incidentes de ciberseguridad

INTERAFAS

Andrea Morúa Bravo
MTO. SERVANDO LOPEZ CONTERAS

Propósito, alcance y clasificación

- **Propósito:** Establecer el marco directivo, operativo y técnico estandarizado para la detección, contención, erradicación, recuperación y análisis post-incidente en INTERAFAS, garantizando la protección de los servicios esenciales de agua potable, alcantarillado y saneamiento frente a amenazas cibernéticas y operacionales.
- **Alcance:** Aplica de manera transversal a los 486 colaboradores, a las instalaciones físicas (51 pozos, 31 tanques, 3 plantas de tratamiento, 12 estaciones de rebombeo), a los sistemas de telemetría y redes IT-OT, así como a los portales web, bases de datos y servicios en la nube del organismo.
- **Concepto de Incidente de Seguridad:** Todo evento adverso confirmado o razonablemente sospechoso que comprometa la confidencialidad, integridad o disponibilidad de la información, de los sistemas informáticos o de la automatización industrial (SCADA/HMI) de INTERAFAS.
- **Criterios de Severidad y Prioridades:**
    - *Baja:* Incidentes sin impacto operativo ni exfiltración de datos (ej. intentos bloqueados de fuerza bruta, alertas menores de firewall).
    - *Media:* Afectación limitada a sistemas administrativos o portales de consulta sin interrumpir el servicio esencial (ej. V01, V02, V04, V06).
    - *Alta:* Compromiso de bases de datos de usuarios, alteración de flujos de pago o vulneraciones BOLA/IDOR (ej. V07, V11, V12, V13).
    - *Crítica:* Afectación directa a la red OT, sistemas HMI, gateways operacionales o inyección de firmware no autorizado (ej. V16, V17, V18, V20).
- **Condiciones de Activación:** El plan se activa de manera automática o mediante reporte directo al Centro de Operación Hidráulica o a la Dirección de Tecnologías e Innovación cuando una alerta de seguridad supere el umbral de severidad Media o comprometa la continuidad operativa.

Roles y responsabilidades

- **Líder del Equipo de Respuesta a Incidentes (CSIRT-Lead): Ing. Bruno Ferrer Lozano** (Encargado de Despacho de Tecnologías e Innovación). Coordina las acciones técnicas de contención y recuperación.
- **Dirección General y Coordinación Ejecutiva: Mtra. Valeria Serrano Cruz** (Encargada de Despacho de la Dirección General). Autoriza decisiones

estratégicas, ventanas de apagado de sistemas y la activación del Plan de Comunicación de Crisis.

- **Responsables Técnicos de Operación e Infraestructura:**
    - *Operación Hidráulica:* **Ing. Tomás Rivas Calderón** (Encargado de Despacho). Gestiona la seguridad en pozos y redes.
    - *Monitoreo Operacional y Telemetría:* **Ing. Emilio Navarro Costa** (Encargado de Despacho). Supervisa variables SCADA y alarmas HMI.
    - *Saneamiento:* **Mtra. Renata Vidal Moreau** (Encargado de Despacho). Asegura la estabilidad en plantas de tratamiento.
- **Apoyo Jurídico y Cumplimiento: Lic. Camila Ortega Neri** (Encargada de Despacho de la Dirección Jurídica). Asesora sobre la preservación legal de evidencia digital y notificación a autoridades.
- **Comunicación Institucional: Mtra. Natalia Correa Vidal** (Encargada de Despacho de Atención Ciudadana). Coordina la difusión de mensajes públicos alineados al Plan de Crisis.
- **Terceros y Proveedores Externos:** Proveedores de servicios en nube (Hosting), pasarelas de pago y soporte especializado de fabricantes OT bajo estrictos acuerdos de confidencialidad (NDA).

Preparación, detección y reporte

- **Preparación:** Mantenimiento de respaldos inmutables, actualización de inventarios de activos (los 20 activos críticos), despliegue de agentes EDR en estaciones de trabajo y realización de simulacros semestrales.
- **Fuentes de Detección:**
    - Monitoreo automatizado de alertas en sistemas SIEM/EDR.
    - Anomalías detectadas en el Centro de Operación Hidráulica (presiones fuera de rango, fallas de telemetría).
    - Reportes directos de usuarios o colaboradores a través de la extensión interna 2401.
- **Recepción y Registro de Alertas:** Toda alerta se registra en el *Ticket de Control de Incidentes de Seguridad (TCIS)*, capturando fecha, hora, sistema afectado, vector sospechoso y nivel preliminar.
- **Canales Oficiales de Reporte:** Correo seguro atencion@interafas.local y línea directa con la coordinación de monitoreo operacional. Línea metropolitana 800 123 9000, Whastapp informativo 4440009000

Análisis y priorización

- **Triage y Validación:** El equipo técnico analiza la alerta en un plazo no mayor a 15 minutos para descartar falsos positivos y confirmar el nivel de afectación sobre los activos.
- **Clasificación y Priorización:** Se asigna prioridad (P1 a P4) basada en el impacto potencial sobre la continuidad del agua potable y la confidencialidad del padrón de usuarios.
- **Preservación de Evidencia:** Antes de realizar cualquier modificación, se aíslan los equipos afectados y se generan copias forenses bit a bit (imágenes de disco y volcados de memoria) manteniendo la cadena de custodia.
- **Escalamiento:** Si el incidente es clasificado como Alto o Crítico, se notifica de inmediato al Comité de Crisis y a la Encargada de Despacho de Dirección General.

Contención

- **Contención Inmediata (Cortoplazo):**
    - Aislamiento de red (*network quarantine*) de los servidores o endpoints comprometidos mediante el EDR o corte físico de enlaces.
    - Revocación inmediata de sesiones activas (PHPSESSID) y bloqueo de credenciales comprometidas.
    - Desactivación temporal de endpoints de API vulnerables (ej. /api/service-history.php) o redirección de tráfico malicioso en el WAF perimetral.
- **Contención Prolongada (Medio plazo):**
    - Activación de rutas redundantes de comunicación y sistemas de respaldo aislados.
    - Mantenimiento de la operación manual vigilada en estaciones de bombeo si el sistema HMI se encuentra bajo sospecha, preservando la continuidad del suministro de agua.

Erradicación y remediación

- **Eliminación de Causas Raíz:**
    - Parcheo y actualización de código fuente vulnerable (eliminación de vulnerabilidades OWASP Top 10 identificadas en V01 a V20).

    - Purgado definitivo de archivos de configuración expuestos (release-check.env, transparencia.php.bak).
    - Supresión de cuentas de usuario apócrifas y eliminación de artefactos de persistencia o *web shells* instalados por el atacante.
- **Validación de Controles:** Antes de reincorporar cualquier componente al entorno de producción, el equipo de ciberseguridad realiza pruebas de penetración internas y escaneos de vulnerabilidades para certificar que la brecha ha sido totalmente cerrada.

Recuperación

- **Restauración Segura:** Reinstalación de sistemas operativos y aplicaciones a partir de imágenes doradas y respaldos limpios verificados (libres de malware).
- **Monitoreo Reforzado:** Durante las primeras 72 horas posteriores a la recuperación, se establece vigilancia 24/7 sobre las bitácoras de red, tráfico de pasarelas y variables de telemetría.
- **Criterios para volver a operación:**
    1. Cero indicios de persistencia del atacante.
    2. Pruebas de integridad superadas al 100%.
    3. Autorización formal por escrito del Encargado de Despacho de Tecnologías y la Dirección General.
- **Mecanismos de Rollback:** Si se detecta inestabilidad tras la restauración, se procede al reavivamiento inmediato de la infraestructura de respaldo secundaria (*failover*).

Coordinación y comunicación

- **Escalamiento Ejecutivo:** Flujo continuo de reportes técnicos hacia las encargadurías de despacho correspondientes.
- **Articulación con Comunicación de Crisis:** Suministro constante de datos técnicos verificados a la Mtra. Natalia Correa Vidal para la elaboración de comunicados oficiales hacia la ciudadanía y medios.
- **Coordinación con Autoridades Externas:** En caso de delitos informáticos graves o afectación a infraestructura crítica nacional, enlace formal con la Policía Cibernética y la Fiscalía General mediante la Lic. Camila Ortega Neri (Jurídico).
- **Terceros y Proveedores:** Notificación a proveedores de nube y pasarelas de pago para auditorías conjuntas de logs transaccionales.

Playbooks operativos

Playbook 01: Respuesta ante Exposición de Credenciales y Archivos de Configuración (V01 / V04)

- **Disparador:** Detección de archivos residuales de despliegue (release-check.env) o respaldos (transparencia.php.bak) accesibles públicamente en servidores web.
- **Responsables:** Ing. Bruno Ferrer Lozano (Tecnologías) / Equipo de Soporte Web.
- **Acciones de respuesta:**
    1. Aislar temporalmente el directorio afectado y eliminar de inmediato los archivos residuales del servidor web.
    2. Revocar y rotar todas las credenciales, llaves API y contraseñas de base de datos expuestas en dichos archivos.
    3. Auditar los registros de acceso (*access logs*) para identificar si agentes externos descargaron o consultaron el archivo.
- **Preservación de Evidencia:** Copia forense de los logs de acceso web donde se visualice la petición al archivo expuesto.
- **Contención y Recuperación:** Aplicación de políticas estrictas de CI/CD para prohibir la inclusión de archivos .env o .bak en despliegues a producción.
- **Criterio de Cierre:** Escaneo automatizado de directorios web con resultado limpio (cero archivos de configuración expuestos).

Playbook 02: Respuesta ante Explotación de Vulnerabilidades BOLA / IDOR en APIs (V03 / V11 / V12)

- **Disparador:** Alerta por consultas masivas no autorizadas o alteración de parámetros numéricos en endpoints de API (/api/service-history.php?account=).
- **Responsables:** Ing. Bruno Ferrer Lozano (Tecnologías) / Desarrollador Backend.
- **Acciones de respuesta:**
    1. Deshabilitar temporalmente el endpoint vulnerable o aplicar una regla de bloqueo perimetral en el WAF.
    2. Modificar la lógica del backend para incorporar validación estricta de propiedad del objeto (verificando que el ID de cuenta pertenezca al usuario de la sesión activa).

3. Revisar bases de datos para descartar exfiltración masiva de datos financieros de usuarios.

- **Preservación de Evidencia:** Extracción de registros de llamadas a la API y patrones de consulta secuencial IP.
- **Contención y Recuperación:** Despliegue de parche de validación de sesión y pruebas unitarias de control de acceso.
- **Criterio de Cierre:** Pruebas de penetración internas confirman la imposibilidad de consultar cuentas ajenas.

Playbook 03: Respuesta ante Manipulación de Flujos de Pago y Lógica de Negocio (V13)

- **Disparador:** Detección de recibos liquidados por montos simbólicos ($1.00 MXN) mediante alteración de parámetros POST en /pago.php.
- **Responsables:** Ing. Bruno Ferrer Lozano (Tecnologías) / C.P. Héctor Salvatierra Ruiz (Administración).
- **Acciones de respuesta:**
    1. Suspender de inmediato la pasarela de pagos afectada y congelar las transacciones sospechosas detectadas en la bitácora.
    2. Modificar el código del servidor para recalcular y revalidar el monto real de la deuda consultando directamente la base de datos por ID de factura, ignorando cualquier valor enviado por el cliente.
    3. Realizar conciliación contable extraordinaria para identificar el daño financiero acumulado.
- **Preservación de Evidencia:** Volcado de la tabla de transacciones de la base de datos y logs de la pasarela de pagos.
- **Contención y Recuperación:** Restablecimiento del portal de pagos bajo validación estricta del lado del servidor.
- **Criterio de Cierre:** Validación de transacciones exitosas con montos reales y cero discrepancias contables.

Playbook 04: Respuesta ante Intrusión en Gateway y Exposición Operacional OT (V15 / V16 / V17)

- **Disparador:** Detección de peticiones maliciosas con suplantación de cabeceras (X-Forwarded-For) en /operations/gateway.php o acceso no autorizado a telemetría.

- **Responsables:** Ing. Tomás Rivas Calderón (Operación Hidráulica) / Ing. Emilio Navarro Costa (Monitoreo Operacional).
- **Acciones de respuesta:**
    1. Bloquear de inmediato la dirección IP de origen y deshabilitar el procesamiento ciego de cabeceras HTTP de proxy en el servidor web.
    2. Cambiar las credenciales de acceso a los paneles de monitoreo y verificar la integridad de las estaciones HMI.
    3. Aislar la red de telemetría de cualquier segmento administrativo expuesto.
- **Preservación de Evidencia:** Captura de paquetes de red (*PCAP*), bitácoras de firewall y registros de acceso al gateway.
- **Contención y Recuperación:** Reforzamiento de políticas de transporte en el servidor web (REMOTE_ADDR) y verificación de variables en pozos.
- **Criterio de Cierre:** Pruebas de suplantación de IP bloqueadas exitosamente por el servidor; telemetría operando con normalidad.

Playbook 05: Respuesta ante Inyección de Firmware No Autorizado en Red Industrial (V18 / V20)

- **Disparador:** Alerta de integridad en controladores industriales (RTUs/PLCs) o detección de intentos de fuerza bruta sobre hashes de actualización de firmware.
- **Responsables:** Ing. Tomás Rivas Calderón (Operación Hidráulica) / Ing. Bruno Ferrer Lozano (Tecnologías).
- **Acciones de respuesta:**
    1. Desconectar físicamente el segmento de controladores afectados de la red de gestión remota para evitar propagación de comandos maliciosos.
    2. Cargar la última versión de firmware legítima firmada criptográficamente (RSA-2048 / SHA-256) desde el repositorio seguro de respaldo.
    3. Realizar una auditoría física de las estaciones de bombeo y tanques para verificar que los parámetros de presión y niveles no hayan sido alterados maliciosamente (*Safety Bounds*).
- **Preservación de Evidencia:** Extracción del binario de firmware no autorizado instalado y volcado de memoria de los controladores.
- **Contención y Recuperación:** Restablecimiento del servicio de bombeo bajo supervisión manual presencial hasta validar estabilidad completa.

- **Criterio de Cierre:** Validación de integridad criptográfica en el proceso de actualización y operación automatizada dentro de rangos normales.

Post-incidente y mejora continua

- **Informe Final de Incidente:** Elaboración de un reporte técnico forense detallado (*Post-Mortem*) en un plazo máximo de 5 días hábiles tras la resolución, documentando cronología, causa raíz, impacto y acciones ejecutadas.
- **Lecciones Aprendidas:** Convocatoria extraordinaria con las encargadurías de despacho para analizar fallas de respuesta y oportunidades de mejora en la arquitectura defensiva.
- **Acciones Correctivas y Actualización de Controles:** Implementación de nuevos controles en la matriz de riesgos del SGSI y actualización de las políticas funcionales correspondientes.
- **Métricas de Desempeño del CSIRT (KPIs):**
    - *Tiempo Medio de Detección (MTTD):* Medido desde el inicio de la brecha hasta su registro oficial.
    - *Tiempo Medio de Respuesta (MTTR):* Medido desde la detección hasta la contención y erradicación exitosa.
    - *Porcentaje de recurrencia de incidentes:* Meta del 0% para vulnerabilidades previamente mitigadas.
- **Seguimiento hasta la Resolución:** La Dirección de Tecnologías mantendrá el seguimiento activo de las acciones correctivas hasta su cierre definitivo en el sistema de gestión.